

RED TEAM REPORT: *PENTESTING DE MY FILE SERVER 1*

Contexto del *Engagement*

Activo Evaluado: Servidor de archivos corporativo My File Server 1

Modalidad: Caja Negra, sin credenciales ni conocimiento previo del sistema

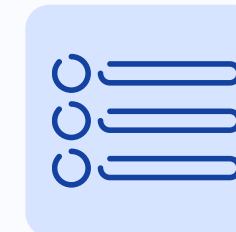
Objetivo: Determinar el nivel de exposición real ante un atacante externo

Alcance: Servicios de red expuestos directamente por el activo (FTP, HTTP, SMB, SSH, NFS)

Metodología : PTES.



Reconocimiento



Enumeración



Explotación



Post-explotación

Se utilizó el estándar PTES - *Penetration Testing Execution Standard*



Nivel General de *Riesgo*

Situación Actual

Con la evaluación, se logró el compromiso total del sistema, escalando privilegios hasta alcanzar *root*.

Esto significa que un atacante externo podría tomar el control absoluto del servidor: **leer**, **modificar** o **eliminar** cualquier archivo, instalar persistencia y alterar registros de auditoría sin ser detectado.

El acceso se obtuvo en menos de una hora, utilizando únicamente herramientas disponibles públicamente y sin necesidad de conocimientos avanzados.

Origen del Riesgo

No se trata de una sola vulnerabilidad, sino de una cadena de fallos acumulados:

- **Exposición de información:** FTP anónimo con acceso a registros internos y archivo /readme.txt con contraseña en texto plano.
- **Configuraciones permisivas:** Sesión SMB nula con recursos de lectura/escritura sin autenticación.
- **Software sin actualizar:** Kernel Linux de 2015, vulnerable a Dirty COW (CVE-2016-5195).
- **Ausencia de endurecimiento:** Servicios con configuraciones por defecto y sin controles de acceso adecuados

Hallazgos Críticos

La evaluación identificó siete hallazgos. Los tres que se presentan a continuación fueron los que, encadenados, permitieron el compromiso total del servidor.

H-05: Kernel vulnerable a Dirty COW

El servidor ejecutaba un kernel Linux de 2015, anterior al parche de Dirty COW. La explotación de esta falla permitió escalar privilegios desde la cuenta smbuser hasta root, otorgando control absoluto del sistema.

Severidad: Crítica

Impacto

Compromiso total. Acceso de lectura y escritura a cualquier archivo, configuración o servicio.

H-01: FTP Anónimo con exposición de registros internos

El servicio FTP aceptó autenticación anónima sin contraseña y exponía una copia completa del directorio /var/log del sistema, incluyendo registros de autenticación, sesiones y actividad interna.

Severidad: Alta

Impacto

Fuga de información operacional. Permite enumerar usuarios y patrones de acceso.

H-02: Contraseña en texto plano en /readme.txt

El archivo /readme.txt era accesible sin autenticación y contenía la contraseña rootroot1 en texto plano. Al combinarse con el usuario smbuser, identificado durante la enumeración SMB, permitió construir credenciales válidas para el acceso inicial.

Severidad: Crítica

Impacto

Obtención directa de una credencial válida sin necesidad de explotación técnica.

File Transfer Protocol Anonimo



Credenciales Expuestas



Acceso SSH



Kernel vulnerable



Root

Escenario de *Impacto* Empresarial

Confidencialidad: Pérdida total. Un atacante con acceso root puede leer cualquier archivo: credenciales, configuraciones, datos de clientes, secretos comerciales.

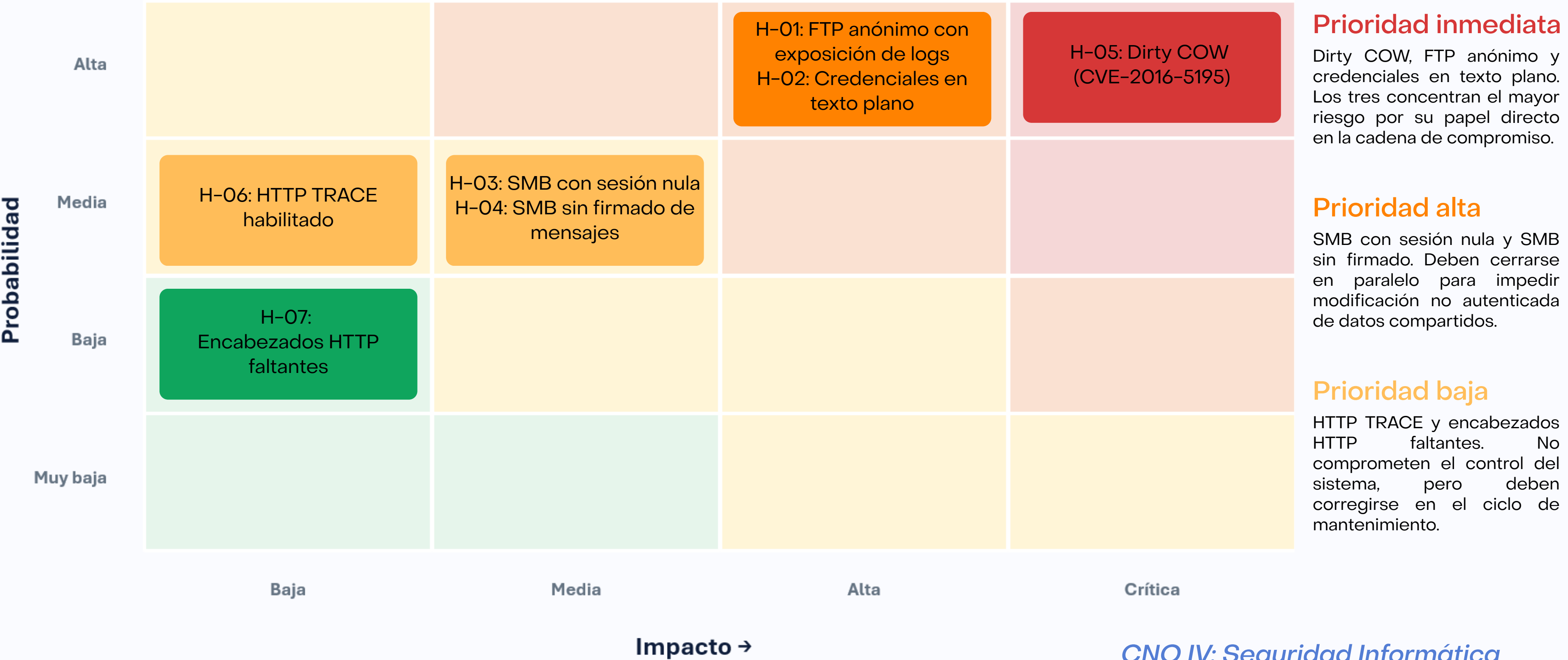
Integridad: Pérdida total. Modificación de binarios del sistema, instalación de puertas traseras, alteración de registros de auditoría para ocultar actividad.

Disponibilidad: Pérdida total. Capacidad de detener servicios, eliminar archivos críticos o dejar el servidor completamente inoperable

Impacto en el negocio: Interrupción operativa, fuga de información sensible, daño reputacional, posibles sanciones regulatorias.

Matriz de *Riesgo*

Priorización cualitativa de los siete hallazgos según su severidad y su facilidad de explotación observada durante la prueba. Los hallazgos en la zona superior derecha representan el mayor riesgo y requieren acción inmediata.

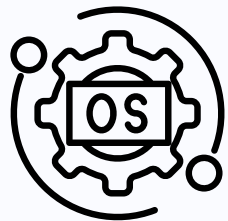


Recomendaciones *Estratégicas*

Acciones priorizadas para reducir el riesgo del activo a un nivel aceptable.

01.
Actualización urgente del kernel

Aplicar parches de seguridad para mitigar Dirty COW. Migrar de CentOS 7 (fin de vida) a una versión con soporte activo



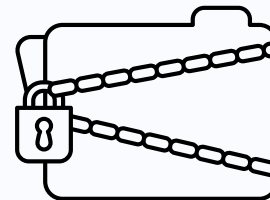
02.
Endurecimiento de servicios

Deshabilitar acceso anónimo en FTP, eliminar credenciales en texto plano, restringir sesiones nulas en Samba, habilitar firmado de mensajes SMB.



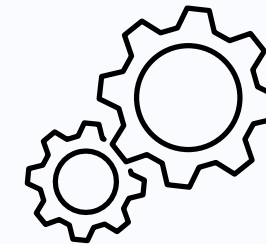
03.
Gestión de secretos

Establecer política que prohíba almacenar o transmitir contraseñas sin cifrado.



04.
Revisión de configuración web

Deshabilitar TRACE, agregar encabezados de seguridad (CSP, HSTS, X-Content-Type-Options).



05.
Monitoreo y auditoría

Implementar registro centralizado de eventos, alertas automáticas para accesos anómalos y auditorías periódicas de configuración.



Roadmap de Remediación

Hoja de ruta para cerrar los hallazgos identificados, ordenada por urgencia y responsable de ejecución.

Plazo	Acción	Responsable	Riesgo que mitiga
Inmediato (0–7 días)	Actualizar kernel, deshabilitar FTP anónimo, eliminar /readme.txt	Equipo de Infraestructura	Dirty COW, exposición de logs y credenciales
Corto plazo (1–4 semanas)	Endurecer Samba, habilitar firmado SMB, revisar permisos de smbdata	Equipo de Seguridad	Acceso no autenticado y manipulación de datos
Mediano plazo (1–3 meses)	Migrar de CentOS 7, implementar gestión de secretos, monitoreo centralizado	TI + Seguridad	Software sin soporte y fuga de credenciales
Largo plazo (3–6 meses)	Programa de hardening continuo, auditorías periódicas, capacitación	Dirección de TI	Recurrencia de configuraciones débiles

Las acciones inmediatas y de corto plazo cierran el 80% del riesgo identificado. El esfuerzo se concentra en las primeras cuatro semanas.

Las acciones de mediano y largo plazo consolidan la postura defensiva y evitan la recurrencia.

Conclusión

- El servidor My File Server 1 presentó un **riesgo crítico**.
- La combinación de configuraciones débiles, credenciales expuestas y software sin actualizar permitió el **compromiso total del sistema** en menos de una hora.
- Las vulnerabilidades identificadas son **conocidas y corregibles**, no requieren soluciones exóticas.
- La aplicación inmediata del roadmap de remediación reduce el riesgo a un nivel **aceptable**.

Priorizar las acciones inmediatas y de corto plazo. El costo de no actuar supera ampliamente el costo de remediar.